سياسة حماية البيانات الشخصية وسرية البيانات

هذه السياسة معتمدة من قبل مجلس الأمناء بتاريخ / /١٤٤٧هـ

نسخة رقم (١)

المادة الأولى: التعريفات

يقصد بالألفاظ والعبارات الآتية -أينما وردت في هذه السياسة- المعاني المبينة أمام كل منها:

- **البيانات الشخصية** :كل بيان -مهما كان مصدره أو شكله- من شأنه أن يؤدي إلى معرفة الفرد على وجه التحديد، أو يجعله قابلاً للتعرف عليه بصفة مباشرة أو غير مباشرة عند دمجه مع بيانات أخرى.
- **البيانات الحساسة** :كل بيان شخصي يتضمن الإشارة إلى أصل الفرد العرقي، أو أصله القبلي، أو معتقده الديني، أو الفكري أو السياسي، أو البيانات الجنائية والأمنية، أو الحيوية، أو الوراثية، أو الائتمانية، أو الصحية، وبيانات تحديد الموقع.
- **صاحب البيانات الشخصية** :الشخص الطبيعي (فرد من العائلة أو مستفيد) الذي تتعلق به البيانات الشخصية أو من يمثله شرعاً.
- **معالجة البيانات** :جميع العمليات التي تجرى على البيانات الشخصية (جمع، حفظ، تحليل، مشاركة، إتلاف).
- **التسريب** :الإفصاح عن البيانات أو تمكين الوصول إليها دون تصريح أو سند نظامي.

المادة الثانية: أهداف السياسة

تهدف هذه السياسة إلى:

١. الحفاظ على خصوصية وسرية البيانات الشخصية لأفراد العائلة والمستفيدين.
٢. تنظيم عمليات جمع ومعالجة البيانات بما يتماشى مع الأنظمة الوطنية.
٣. الامتثال لمتطلبات حوكمة البيانات الصادرة عن المركز الوطني لتنمية القطاع غير الربحي.

المادة الثالثة: نطاق التطبيق

تطبق أحكام هذه السياسة على كافة عمليات معالجة البيانات الشخصية التي تتم داخل الصندوق، ويستثنى من ذلك حالات الإفصاح للمصالح العامة أو الأمنية أو القضائية، أو إذا كانت البيانات معالجة بطريقة لا تؤدي لتحديد هوية صاحبها.

المادة الرابعة: الغرض من الجمع والبيانات المستهدفة

١. يتم جمع البيانات لغرض تحليل احتياجات أفراد العائلة، لتسهيل تقديم أي خدمة لهم ينفذها الصندوق، وقياس رضا المستفيدين.
٢. تشمل البيانات المجمعة: (الاسم الثلاثي، الجنسية، المنطقة، المدينة، الجنس، رقم الهوية، رقم الجوال، وتفاصيل الخدمات المقدمة).

المادة الخامسة: آلية جمع البيانات

يتم الحصول على البيانات مباشرة من صاحبها عبر:

- الوسائل المباشرة :الاتصال الهاتفي من منسوبي الصندوق أو المقابلات الشخصية.
- الوسائل غير المباشرة :المراسلات الإلكترونية أو النماذج الرقمية ومع الجهات ذات العلاقة.

المادة السادسة: مبادئ المعالجة

يلتزم الصندوق عند معالجة البيانات بالمبادئ الآتية:

- **المسؤولية** :اعتماد السياسات من المسؤول الأول ونشرها لجميع المعنيين.
- **الشفافية** :إعداد إشعار خصوصية يوضح أغراض المعالجة بكل وضوح.
- **المو افقة** :الحصول على موافقة صاحب البيانات (ضمنية أو صريحة) قبل المعالجة.
- **الحد من البيانات** :الاكتفاء بالحد الأدنى من البيانات اللازمة لتحقيق الغرض.
- **الجودة** :ضمان دقة البيانات واكتمالها وتحديثها بانتظام.

المادة السابعة: حفظ البيانات و إتلافها

يتم الاحتفاظ بالبيانات الشخصية وفق الضوابط الآتية:

١. **مدة الاستبقاء** :يتم الاحتفاظ بالبيانات طالما كان ذلك ضرورياً لتحقيق الأغراض التي جمعت من أجلها (مثل مدة عضوية الفرد في الصندوق أو استمرار استحقاقه للمساعدة أو استمراره في احدى خدمات الصندوق).

٢. **الأرشفة** :تُنقل البيانات غير النشطة إلى أرشيف إلكتروني آمن ومحمي، ويتم تقييد الوصول إليها إلا لأغراض التدقيق أو الامتثال النظامي.

٣. **النسخ الاحتياطي** :يلتزم المسؤول التقني بإجراء نسخ احتياطي دوري (كل أسبوعين كحد أدنى)، مع حفظ النسخ في بيئة سحابية آمنة ومنفصلة عن بيئة العمل المباشرة لضمان استعادة البيانات في حالات الكوارث الرقمية.

المادة الثامنة: أمن البيانات

يلتزم الصندوق بتطبيق أقصى معايير الحماية التقنية لمنع الاختراق أو الفقدان الصادرة عن الهيئة الوطنية للأمن السيبراني لحماية البيانات من الاختراق أو الفقدان، وفقاً للضوابط التالية:

١. **إدارة الوصول** :يجب تفعيل خاصية التحقق الثنائي (MFA) لجميع الأنظمة السحابية والبرمجية التي تحتوي على بيانات أفراد العائلة.

٢. **تخزين البيانات في موقع الكتروني خاص بالصندوق أو منصة سحابية موثوقة مثل (OneDrive أو Google Drive)**

٣. **تشفير البيانات** :تُشفر جميع البيانات الحساسة (مثل أرقام الهويات والمبالغ المالية) في حالة التخزين (At Rest) وفي حالة الانتقال عبر الشبكات باستخدام بروتوكولات آمنة مثل(HTTPS)

٤. **حماية الأجهزة** :يلتزم الصندوق بتثبيت برامج مكافحة الفيروسات المعتمدة على كافة الأجهزة المستخدمة، مع تفعيل التحديث التلقائي لأنظمة التشغيل لسد الثغرات الأمنية.

٥. **عزل البيانات** :يُحظر تخزين بيانات الصندوق في أجهزة شخصية غير محمية أو وسائط تخزين عامة غير مشفرة.

المادة التاسعة: الإفصاح للأطراف الخارجية

يُحظر الإفصاح عن البيانات الشخصية لأي طرف خارجي إلا في الحالات المحددة في إشعار الخصوصية أو بعد الحصول على موافقة صاحب البيانات، مع مراعاة المصالح المشروعة للصندوق بما لا يخل بحقوق الأفراد.

المادة العاشرة: الرقابة والامتثال

يتولى المسؤول الأول في الصندوق (أو من يفوضه) مراقبة الامتثال لهذه السياسة، واستقبال الشكاوى المتعلقة بالخصوصية والعمل على معالجتها فوراً.

المادة الحادية عشرة: المخالفات والجزاءات الإدارية

١. يعتبر أي إخلال بأحكام هذه السياسة، أو إساءة استخدام للبيانات الشخصية، أو تمكين الوصول إليها لغير المصرح لهم، مخالفة تستوجب المساءلة الإدارية.
٢. يتولى الصندوق إيقاع الجزاءات التالية على المنسوبين المخالفين (سواء كانوا موظفين أو متطوعين) مع عدم الإخلال بالعقوبات المقررة نظاماً في "نظام حماية البيانات الشخصية":
   - **الإنذار الكتابي** :في حال المخالفات غير المقصودة التي لم تؤدِّ إلى ضرر جسيم.
   - **تعليق الصلاحيات** :سحب صلاحيات الوصول إلى الأنظمة والبيانات مؤقتاً أو نهائياً.
   - **إنهاء العلاقة** :في حال تعمد تسريب بيانات حساسة أو تكرار المخالفة بما يضر بمصلحة الصندوق أو أفراده.
٣. يلتزم كل من اطلع على بيانات شخصية بحكم عمله أو تطوعه في الصندوق بالمحافظة على سريتها حتى بعد انتهاء علاقته بالصندوق.

المادة الثانية عشرة: سياسة إتلاف البيانات الشخصية

عند انتهاء الغرض من معالجة البيانات، أو بناءً على طلب صاحب البيانات (في الحالات التي يسمح بها النظام)، يتم إتلاف البيانات وفق الآتي:

١. **الإتلاف الرقمي** :مسح البيانات من الخوادم والأقراص الصلبة والنسخ الاحتياطية بطريقة تقنية تضمن عدم إمكانية استعادتها مرة أخرى .
٢. **الإتلاف الورقي** :يتم تمزيق الوثائق والمستندات الورقية التي تحتوي على بيانات شخصية باستخدام أجهزة إتلاف الورق (Shredders)، ويُحظر رميها في النفايات العامة بشكلها المقروء.
٣. **محضر الإتلاف** :يتم تحرير محضر إتلاف داخلي يوضح نوع البيانات التي تم التخلص منها، التاريخ، والجهة المسؤولة عن الإتلاف، ويُعتمد من المسؤول الأول.

المادة الثالثة عشرة: الاستجابة لحوادث تسريب البيانات

في حال حدوث اختراق تقني أو فقدان للبيانات، يجب على الصندوق اتباع الإجراءات التالية:

١. عزل الأنظمة المتضررة فوراً لمنع تفاقم التسريب.

٢. إبلاغ المسؤول الأول بالصندوق والجهات المختصة (مثل المركز الوطني أو سدايا) خلال المدة النظامية المحددة في حال كان الاختراق يشكل خطراً على حقوق أصحاب البيانات.

٣. إخطار أصحاب البيانات المتضررين في حال كان التسريب يمس بياناتهم الحساسة أو قد يلحق بهم ضرراً.

المادة الرابعة عشرة: المراجعة والتدقيق التقني

يخضع النظام التقني للصندوق لعملية مراجعة دورية (كل سنة ميلادية) للتأكد من فاعلية التشفير، والنسخ الاحتياطي، وصلاحيات الوصول، ومدى مواءمتها مع تحديثات الهيئة الوطنية للأمن السيبراني.

المادة الخامسة عشرة: النفاذ والمراجعة

تعتبر هذه السياسة نافذة من تاريخ اعتمادها من قبل المسؤول الأول في الصندوق (الرئيس التنفيذي أو مجلس الإدارة)، وتخضع للمراجعة الدورية لتواكب أي تحديثات في الأنظمة واللوائح الصادرة عن المركز الوطني لتنمية القطاع غير الربحي أو الهيئة السعودية للبيانات والذكاء الاصطناعي (سدايا).

نموذج تعهد التزام وسرية البيانات الشخصية

أنا الموقع أدناه الاسم الرباعي: **رقم الهوية:**

الصفة (موظف/متطوع/عضو):

أقر وأتعهد بالآتي:

١. **الاطلاع والالتزام :** بأنني اطلعت على "سياسة حماية البيانات الشخصية" الخاصة بالصندوق، وألتزم بكافة موادها وأحكامها أثناء أداء مهامي.

٢. **السرية التامة :** بالمحافظة على سرية كافة البيانات الشخصية والحساسة التي أطلع عليها بحكم عملي، وعدم الإفصاح عنها أو تسريبها أو نشرها بأي وسيلة كانت، سواء بقصد أو بغير قصد.

٣. **الاستخدام المحدود :** بأنني لن أستخدم البيانات الشخصية لأفراد العائلة والمستفيدين إلا للأغراض المحددة والضرورية لعمل الصندوق فقط، وعدم استخدامها لمصالح شخصية أو تجارية.

٤. **أمن المعلومات :** بالمحافظة على كلمات المرور ووسائل الوصول للبيانات، وعدم مشاركتها مع أي طرف آخر، وإبلاغ المسؤول فوراً في حال اشتباهي بوجود اختراق أو تسريب.

٥. **استمرار الالتزام :** بأن التزامي بالمحافظة على سرية البيانات يظل قائماً ونافذاً حتى بعد انتهاء علاقتي بالصندوق (استقالة، انتهاء تكليف، أو غير ذلك).

٦. **المسؤولية القانونية :** بأنني أدرك تماماً أن أي مخالفة لهذا التعهد ستعرضني للمساءلة الإدارية داخل الصندوق، وللعقوبات المقررة في "نظام حماية البيانات الشخصية" والأنظمة ذات العلاقة في المملكة العربية السعودية.

وعلى ذلك أوقع،،

التاريخ: / / **١٤٤هـ** **التوقيع:**